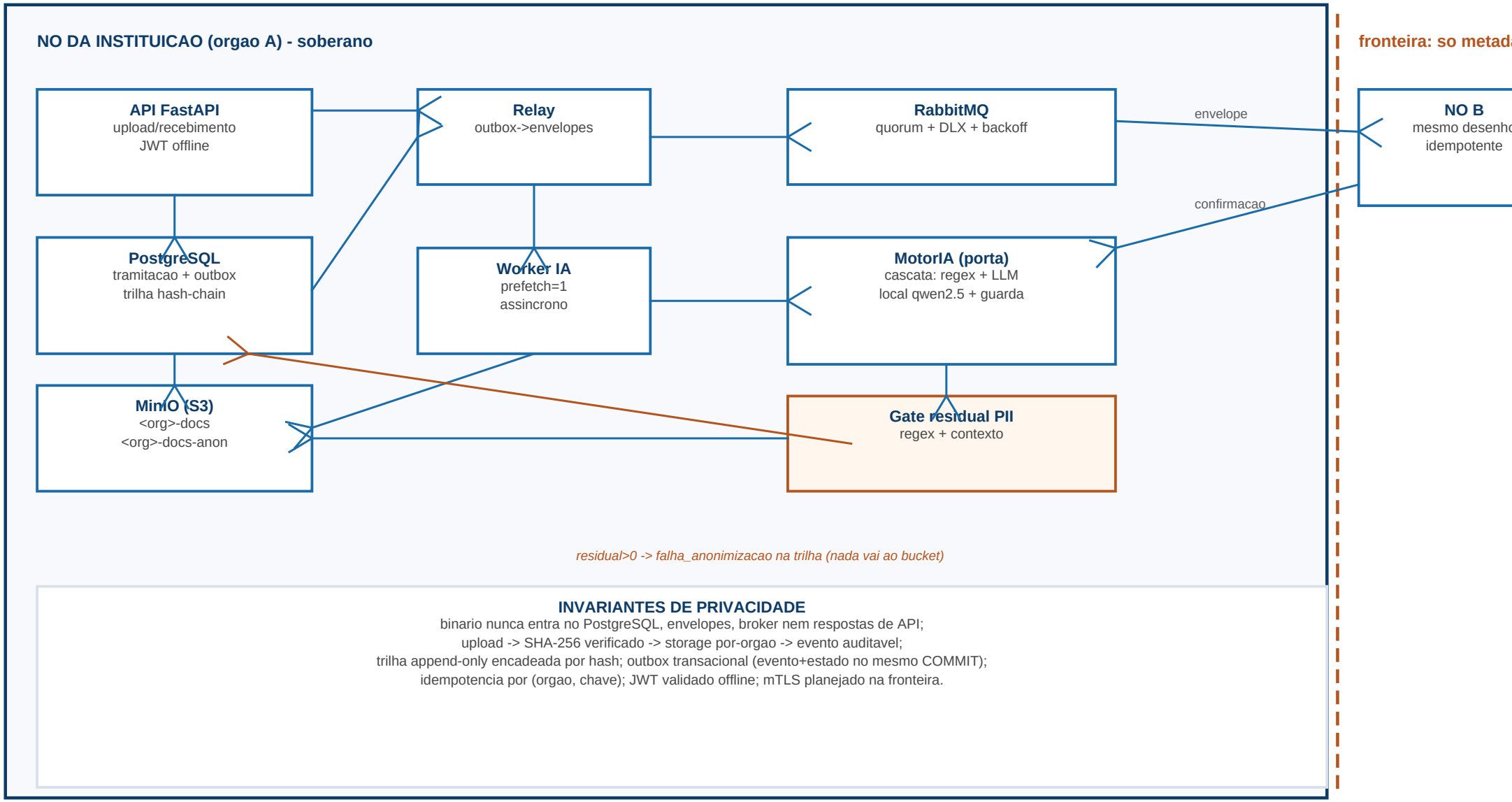
iSACI - no soberano de anonimizacao e tramitacao

PIDE / FAPESPA - POC de arquitetura - documento de apresentacao

Principio estruturante: cada instituicao roda um no de borda soberano - guarda, processa e assina os proprios documentos. O que atravessa a fronteira entre organizacoes sao apenas envelopes de metadados (hashes, IDs, estado); nunca o documento binario nem texto extraido.

Desenho da arquitetura



O fluxo, em algoritmo

O mesmo desenho, lido como sequencia de passos.

```
UPLOAD (no A)
1  recebe metadados + SHA-256 do documento
2  se (orgao, chave) ja existe -> devolve resultado
   cometido            // idempotente: reenvio = eco
3  recebe binario (multipart) -> verifica SHA-256
4  hash confere? nao -> rejeita; sim -> grava em
   <org>-docs
5  num unico COMMIT: trilha += doc_arquivado:{id}
                outbox += ia.anonimizacao:{id}
      // evento e estado vivem ou morrem juntos
```

```
ANONIMIZACAO (worker, fila ia.anonimizacao)
6  baixa o bruto -> MotorIA.anonimizar(bytes)
   // cascata: regex -> spans LLM -> so-nomes ->
   // guarda -> substituicao por codigo
7  saida ilegivel? -> trilha += falha; NACK;
   FIM
8  pii_residual(saida) > 0? ->
   trilha += falha:residual_pii; sem gravacao;
   // fail-closed
   ACK; FIM
9  grava em <org>-docs-anonimizados;
   trilha += doc_anonimizado:{id}; ACK
```

```
TRAMITACAO A -> B
10 trilha += criada:{id}; outbox += envelope
   // envelope = so metadados + hash; nunca binario
11 relay publica com retry limitado -> EM_TRANSITO
12 B recebe (idempotente) -> RECEBIDA; 1o ingresso
   traz hash_cadeia
13 B decide -> CONFIRMADA | RECUSADA | CANCELADA
14 esgotou retry? -> estado EXAUSTO (visivel,
   auditado)
15 reconciliador varre EM_TRANSITO antigos ->
   reencaminha   // 'perdido em transito' nao vira
   // buraco
```

Quem liga com quem (o diagrama em texto)

- API FastAPI -> PostgreSQL: estado da tramitacao, evento de trilha e evento de outbox numa unica transacao.
- PostgreSQL -> MinIO: binario (SHA-256 verificado) vai para <org>-docs; a coluna da esquerda encadeia upload -> registro -> objeto.
- PostgreSQL -> Relay: o relay le os eventos pendentes da tabela outbox.
- Relay -> RabbitMQ: publica o envelope (so metadados + hash).
- Relay -> Worker IA: sinaliza o processamento assincrono pendente.
- RabbitMQ -> No B: o envelope atravessa a fronteira (linha tracejada) - e a unica coisa que sai do no.
- No B -> RabbitMQ: a confirmacao (RECEBIDA/hash_cadeia) volta pelo mesmo caminho.
- Worker IA -> API/PostgreSQL (retorno superior): grava doc_anonimizado:{id} ou falhas na trilha.
- Worker IA -> MinIO (retorno inferior): baixa o bruto de <org>-docs.
- Worker IA -> MotorIA: entrega os bytes para anonimizar().
- MotorIA -> Gate residual PII: o texto anonimizado desce para validacao.
- Gate residual -> MinIO: se residual=0, grava em <org>-docs-anonimizados.
- Gate residual -> PostgreSQL (seta laranja): se residual>0, NADA e gravado - a falha falha_anonimizacao:{id}:residual_pii vai para a trilha.

Conceitos-chave

PII (Personally Identifiable Information): dado que identifica uma pessoa (nome, CPF, RG, e-mail, telefone, endereco). Objeto de protecao da LGPD e alvo da anonimizacao.

No soberano / fronteira: cada instituicao roda o proprio no e guarda os proprios documentos; entre nos circulam so envelopes de metadados (ID, hash, estado) - nunca binario nem texto extraido. Nao existe ponto central onde o PII se concentre.

Envelope e hash: mensagem A->B com identificadores e o SHA-256 do documento; o hash e a impressao digital que prova correspondencia entre o declarado e o recebido.

Outbox transacional: o evento e gravado na mesma transacao da mudanca de estado: se o commit falha, nada e publicado - elimina o 'mudou e ninguem foi avisado'. Um relay drena e publica.

Trilha de auditoria (hash-chain): log append-only onde cada evento carrega o hash do anterior: alterar um evento antigo invalida os seguintes - adulteracao e detectavel por verificacao.

Idempotencia e at-least-once: o broker pode entregar 2x; o no B reconhece duplicata pela chave e devolve o resultado ja cometido - reenvio e eco, nao novo efeito.

Quorum + DLX: filas replicadas toleram replica morta; mensagem que falha alem do delivery-limit vai para a fila-morta (DLQ) - erro permanente vira estado visivel, nao loop.

MotorIA - porta permutavel: contrato anonimizar(bytes)->bytes: stub, demo-regex, Ollama e o futuro NER discriminativo implementam a mesma interface; trocar o motor nao toca o pipeline.

Cascata det + LLM: regex pega CPF/RG/e-mail/telefone/endereco; LLM local extrai spans semanticos; guarda protege CNJ/VALOR; a substituicao e feita por codigo - o LLM aponta, o codigo apaga.

PII residual e o gate de saida: PII residual = dado pessoal que sobrou no texto ja anonimizado. Se residual>0, o gate bloqueia a gravacao no bucket e encadeia falha_anonimizacao:{id}:residual_pii na trilha, contando so quantidades - falha vira evento auditavel, nao vazamento silencioso (fail-closed).

NER exact x overlap: exact exige fronteira identica ao gabarito; overlap aceita sobreposicao parcial. Teste: exact F1 0,755 (gate 0,85 reprovou) x overlap F1 0,938 - o motor encontra quase tudo, mas delimita mal.

Reidentificacao por mencao x documento: 4/360 entidades (1,1%) x 4/80 documentos (5,0%). A unidade de risco LGPD e o documento - um doc com um nome residual ja expoe uma pessoa.

ADR-0011 - zero IA generativa: decisao registrada: processamento local deterministico/discriminativo. O LLM da cascata e desvio documentado da POC; voltar a ADR = NER discriminativo treinado medido no mesmo gate. Aceitar o desvio e decisao do requisitante.

O que cada tecnologia decide

Tecnologia	Papel	O que influencia / garante
FastAPI + pydantic	contrato HTTP do no	**validacao de envelope na borda; nada de binario em resposta**
PostgreSQL + SQLAlchemy + Alembic	estado, outbox, trilha	**outbox transacional (evento gravado na mesma transacao do estado: se o commit falhar, nada e publicado); trilha hash-chain verificavel**
RabbitMQ (quorum + DLX)	envelopes e fila de anonimizacao	**quorum tolera replica morta; DLX + delivery-limit isolam mensagem envenenada; prefetch=1**
MinIO (S3)	objetos por orgao	**buckets <org>-docs/-anonimizados: isolamento fisico; binario fora do banco e do broker**
Worker (aio-pika)	esteira IA assincrona	**ACK so apos upload+trilha (at-least-once); falha -> NACK+requeue; desacopla latencia do modelo**
Relay	drenador do outbox	**retry/backoff limitado + exaustao explicita + reconciliador de 'perdidos em transito'**
MotorIA (porta)	anonimizar(bytes)->bytes	**contrato permutavel (stub/demo/Ollama): a arquitetura nao depende do motor**
Ollama + qwen2.5 7B/14B	detector semantico local	**processamento on-prem, temperature=0; experimento documentado (desvio da ADR-0011, decisao do requisitante)**
pii_residual	gate de saida	**residual>0 -> falha_anonimizacao:residual_pii na trilha; nada vai ao bucket anonimizado**
JWT offline + HMAC	autenticacao/integridade	**validacao sem IdP online (soberania); mTLS planejado na fronteira entre nos**
Docker Compose	empacotamento do no	**no reproduzivel por instituicao: api+db+broker+minio+worker+relay**
pytest (smoke e2e)	verificacao	**upload dedup, reconciliacao, outbox retry, DLQ, gate residual - a suite e o contrato**
fpdf2 / pypdf	corpus e relatorio	**geracao de PDF sem quebrar entidade e relatorio de avaliacao - medicao, nao pipeline**

Fluxos essenciais

Upload e registro

- metadados + SHA-256 registrados; idempotencia por (orgao, chave);
- upload multipart -> hash verificado -> objeto em <org>-docs;
- doc_arquivado:{id} na trilha + evento outbox na mesma transacao.

Tramitacao A -> B

- criada:{id}; outbox publica envelope (metadados, nunca binario);
- B recebe idempotentemente; 1o ingresso retorna hash_cadeia; duplicata devolve o resultado ja cometido;
- estados CRIADA -> EM_TRANSITO -> RECEBIDA -> CONFIRMADA / RECUSADA / CANCELADA;
- relay multi-replica com backoff limitado; reconciliador reencaminha perdidos; exaustao e estado explicito.

Anonimizacao (esteira IA)

- outbox ia.anonimizacao -> worker (prefetch=1);
- bruto -> MotorIA.anonimizar (cascata: regex + spans LLM + passada so-nomes + guarda CNJ/VALOR + substituicao por codigo);
- gate de legibilidade: saida ilegivel -> falha na trilha, sem gravacao;
- gate residual: PII residual -> falha_anonimizacao:{id}:residual_pii, sem gravacao;
- sucesso -> <org>-docs-anonimizados + doc_anonimizado:{id} -> ACK.

O que a avaliacao mediu

Cascata na particao teste (80 docs, held-out): recall agregado 356/360 (98,9%); excesso em preservados 0/305; reidentificacao por mencao 4/360 (1,1%, dentro do gate <=0,05) e por documento 4/80 (5,0%, limite dentro do IC). NER exact F1 0,755 - abaixo do gate 0,85 (fronteiras frouxas dos spans LLM). Detalhe: docs/relatorio_avaliacao.pdf.

Leitura honesta: a arquitetura esta validada como desenho; o motor e candidato de POC, nao aprovado para producao - o gate NER exact reprovou e o uso de LLM generativo local e desvio documentado da ADR-0011, cuja aceitacao cabe ao requisitante.